STAC AI BOOTCAMP NYC



Deployment and governance clinic

Matthew Dixon, PhD, FRM
BeliefLens

21 October 2026 | 4:15–5:00

matthew.dixon@belieflens.org

The decision this session makes

Notebook: `07_governance.ipynb`

- A plausible answer is only a proposal.
- An operating system must decide what may happen next.
- Our deliverable: a release rule, an accountable owner and a reproducible decision record.

Why this matters: Turn evaluation findings into an enforceable operating process.

Roadmap: from purpose to permitted action

1. Define scope, harms and decision rights.
2. Separate evidence checks from authority controls.
3. Use a graph to route gaps and disputed claims.
4. Recheck at execution; monitor and requalify.
5. Apply the design to one workflow.

Why this matters: Each concept produces a part of the deployment plan.

Five learning objectives

- 7.1 Specify the workflow boundary and allowed actions.
- 7.2 Map evidence requirements to checks, experts and records.
- 7.3 Explain when a runtime gate can guarantee authority limits.
- 7.4 Choose monitoring and requalification triggers.
- 7.5 Design a bounded pilot and test its governance controls.

Why this matters: Assess design decisions rather than memorized terminology.

Start with a system boundary

- Name the user, task, affected people and intended benefit.
- List inputs, tools, external services and possible actions.
- Separate recommendation, approval and execution rights.
- State excluded uses, reversal options and an accountable owner.

Why this matters: A risk assessment requires a defined system and consequence.

A lifecycle, not a final approval meeting

Function	Practical question
Govern	Who sets policy and owns the consequences?
Map	What is the task, context and potential harm?
Measure	What evidence tests performance and limitations?
Manage	What changes, restrictions or response follow?

Why this matters: Use findings to revise scope, controls or deployment.

Policy and mechanism are different

- **Policy:** which behaviors are allowed?
- **Mechanism:** what actually prevents a disallowed behavior?
- **Assumption:** which routes and components must the mechanism control?

Why this matters: A prompt instruction alone does not establish an authority boundary.

Two questions at every release

Evidence and meaning

Is the conclusion supported?

Are sources applicable?

Are material gaps unresolved?

Authority and current state

May this actor take this action?

Is approval still valid?

Has the relevant state changed?

Why this matters: Passing one side does not imply passing the other.

Specify requirements before scoring evidence

- **R1 — Decision:** define purpose, population, metric and period.
- **R2 — Evidence:** require eligible sources and declared coverage.
- **R3 — Inference:** test whether comparisons support the claim.
- **R4 — Authority:** require current permission and accountable release.

Why this matters: Enough evidence means meeting requirements for a stated decision.

Document the population behind the source

- Who or what was sampled, and who is missing?
- How were records collected and selected?
- Which uses and comparisons are supported?
- Which collection details are unknown?

Why this matters: A large source can still be unsuitable for the question.

Which is better: Giants or Patriots?

GOVERNANCE CASE · SAME QUESTION-FIRST STRUCTURE AS MARMITE / VEGEMITE

NEW YORK GIANTS

American football



NEW ENGLAND PATRIOTS

American football



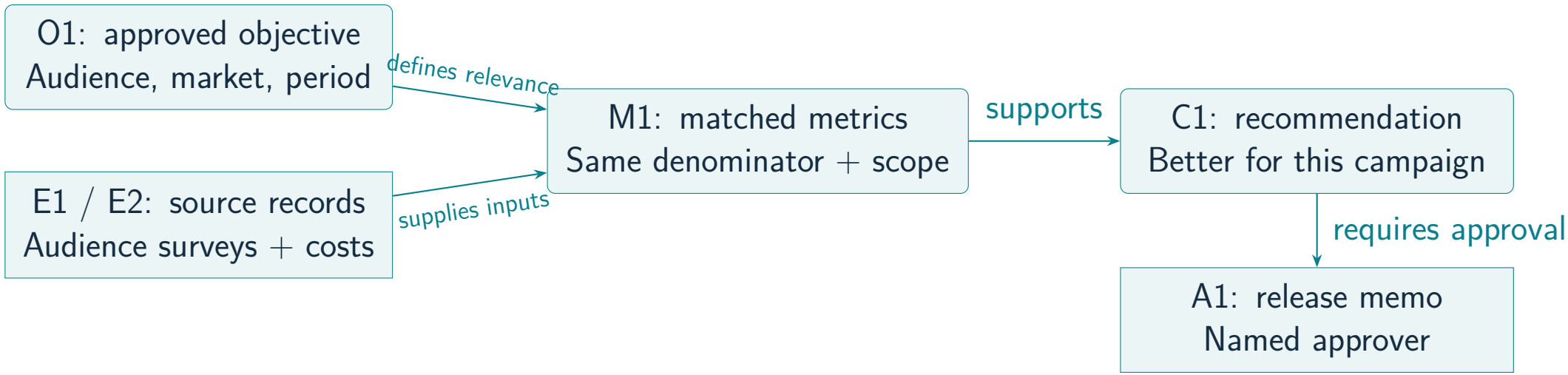
Human> Which team is better?

- Better for whom: a fan, sponsor or investor?
- Better on what: sporting success, audience reach or commercial return?
- Over which period, market and comparison population?

First decision: clarify the comparison before ranking the teams.

Map the question to its evidence and decision

HYPOTHETICAL SPONSORSHIP DECISION · NO TEAM RANKING IS ASSERTED



Rule attachments: R1 at O1; R2 at E1/E2; R3 on $E \rightarrow M \rightarrow C$; R4 at A1.

The governance matrix: checks, experts and decisions

General rule	Specific check / graph target	Action + expert	Required record
R1: Define the decision	O1: Is "better" an agreed campaign objective?	Clarify; business owner	Signed metric, scope and period
R2: Check the evidence	E1/E2: One team's fan poll only? Missing equivalent source for the other?	Hold comparison; data steward + survey specialist	Sampling frame, provenance, coverage gaps
R3: Validate the inference	$E \rightarrow M \rightarrow C$: Same population, units and period? Does reach imply return?	Qualify or escalate; statistician + commercial expert	Matched comparison, uncertainty and assumptions
R4: Authorize the action	A1: Material checks resolved and approval current?	Release or withhold; named approver	Rule version, check results and signed decision

People define the policy. Software evaluates declared checks, traces impact and routes exceptions.

So what decision does the graph support?

- **Clarify:** no agreed meaning of "better" ⇒ request objective and scope.
- **Escalate:** unmatched audiences or missing source methods ⇒ route the affected comparison to experts.
- **Withhold:** unresolved material support gap ⇒ block the team-ranking claim, not every unrelated fact.
- **Release:** comparable evidence, bounded claim and current approval ⇒ publish the scoped memo with limitations.

Illustrative governed response

"Define the campaign audience and success metric. Withhold the ranking until material coverage gaps are resolved."

Discussion: Trace one failed requirement to its owner and allowed action.

What the graph contributes

- A typed record: source, measurement, claim and proposed action.
- A dependency: which claim uses which source or calculation?
- A rule attachment: where is a requirement checked?
- A repair scope: which dependent checks must run again?

Why this matters: Localize the affected decision instead of rejecting every output.

Question: many sources, one population

- A comparison uses 100 surveys, all from one team's fan club.
- A. Release: the source count is large.
- B. Ask a model whether the evidence feels balanced.
- C. Check the target population; escalate the coverage gap.

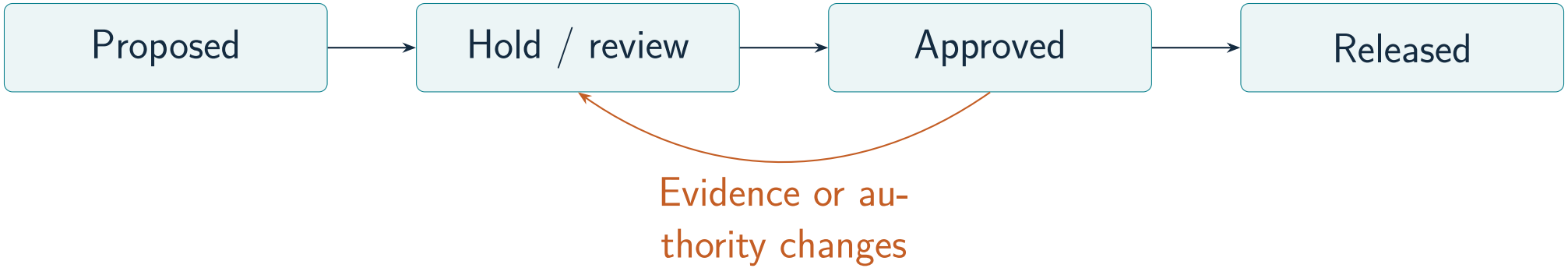
Why this matters: Apply R2 to the sampling frame, not the number of documents.

Answer: C — check coverage

- The question concerns a wider audience than the sample.
- Record the missing population coverage and affected claim.
- The survey specialist assesses a valid replacement or narrower claim.

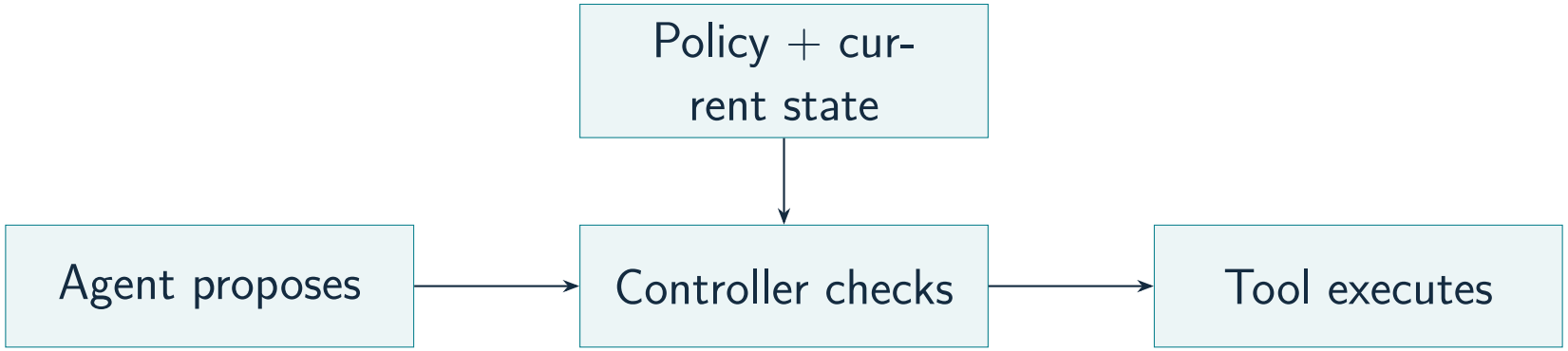
Why this matters: Unknown representativeness is a reason to qualify or withhold the comparison.

From a check to an operational state



Why this matters: Resolution and approval are separate transitions.

Place enforcement at the action boundary



Why this matters: Every protected action must pass through the controller.

A commit-time predicate

$$\text{allow}(a, s) = E(a, s) \wedge P(a, s) \wedge V(a, s) \wedge U(a, s).$$

- a: proposed action; s: current system state; allow: Boolean permission to execute; $\wedge$: logical AND (all tests must pass).
- E: required evidence checks passed; P: current permission and approval cover the action.
- V: source and state versions still match; U: action has not already been committed. Every test returns true or false, with no physical unit.
- Read: permit only if all prerequisites hold now. Requires protected state and an atomic check-and-dispatch boundary.

What could actually be proved?

- Specified invariant: no committed action exceeds its valid grant.
- Assumptions: every execution is mediated; checks and state are correct.
- Required controls: no bypass credentials; protected policy; atomic checks.
- Outside the claim: truth of evidence, business success, unknown threats.

Why this matters: A guarantee is only as strong as its model and assumptions.

Question: approved at 08:55

- At 08:59 the grant is revoked. Execution is scheduled for 09:00.
- A. The earlier approval is enough.
- B. Recheck current authority and block the action.
- C. Ask the language model to choose.

Why this matters: Distinguish an earlier recommendation from current authority.

Answer: B — recheck at execution

- A saved approval is evidence of a past decision.
- The controller checks the live grant and bound proposal.
- A revoked grant blocks the operation and records the reason.

Why this matters: Authorization must remain valid when the action occurs.

When do MDPs become relevant?

Structure	Appropriate use
Fixed predicate	A known prerequisite permits or blocks an action.
State machine	Earlier approvals, retries and commits affect current permission.
MDP	Choose sequential interventions using state, transitions and costs.
POMDP	Relevant state is partly hidden; observations update a belief.

Why this matters: Use sequential optimization when actions change future information or consequences.

A decision policy still needs hard limits

$$\pi(s) \in \mathcal{A}_{\text{allowed}}(s), \qquad V^{\pi}(s) = \mathbb{E}_{\pi}\left[\sum_{t=0}^{T} \gamma^{t} r_t \mid s_0 = s\right].$$

- s: state; π: action-selection policy; $\mathcal{A}_{\text{allowed}}(s)$: permitted actions there; $\in$: belongs to.
- $V^{\pi}(s)$: expected cumulative value under that policy; $\mathbb{E}_{\pi}$: average over resulting trajectories; s_0: initial state.
- t: step index; T: last step; r_t: reward in declared utility/cost units; $\gamma \in [0, 1]$: unitless discount; Σ: sum; $|$: conditional on.
- Read: choose within authority, then assess expected discounted consequences. Rewards and transitions need validation; an agent need not use reinforcement learning.

Question: which needs sequential reasoning?

- A. Block a tool call with an expired grant.
- B. Verify that a signed source exists.
- C. Decide whether another investigation is worth its delay and cost.

Why this matters: Recognize when the next action changes future options.

Answer: C — value of more information

- Investigation can change the evidence available for a later decision.
- Its value depends on uncertainty, cost and consequences.
- A and B can be enforced using fixed checks.

Why this matters: Add model complexity only when it improves the decision design.

Test the controller as well as the model

- Valid case: release should succeed under unchanged conditions.
- Fault cases: missing evidence, stale state, revoked grant, duplicate request.
- Measure false releases, false holds and review burden by failure type.
- Keep independent expected outcomes and a held-out test set.

Why this matters: An impressive model score does not establish a working release gate.

Monitor what invalidates qualification

- Input health: missing fields, source coverage and changed distributions.
- System health: timeouts, missing traces, stale models and service changes.
- Decision health: unsupported releases, override rates and delayed outcomes.
- Version health: model, prompt, corpus, tools, policy and grants.

Why this matters: Deployment approval does not survive every change automatically.

A trigger starts diagnosis, not automatic retraining

Finding	First response
Missing or stale source	Repair ingestion / retrieval; recheck affected claims.
Tool schema or calculation error	Fix integration; rerun relevant tests.
Task behavior fails with valid inputs	Review prompt or adaptation data; compare on held-out cases.
Scope or policy changes	Reassess permitted use and approval requirements.

Why this matters: Change the failing component and requalify the affected workflow.

Class Exercise: authorization must survive until execution

- Open `07_governance.ipynb`; run setup C01.
- C02: prepare and commit; verify one order and no duplicate dispatch.
- C03: prepare afresh, revoke the grant, commit; inspect the failed check.
- Change `grant` to `pending` or `snapshot`; rerun C03.
- C04: run all state changes; compare decisions, order counts and audit records.

Design your own governed pilot

APPLY 7.1, 7.2, 7.3, 7.4, 7.5

Work in pairs; report a decision and its evidence.

- Choose one workflow; state its user, inputs, output, prohibited action and accountable owner.
- Define two blocking rules, one escalation path, a safe-control case and two fault cases.
- Name the logs, change triggers and pilot exit criteria. Present a release decision under one injected fault.

What the pilot must produce

- A scope and authority record: objective 7.1.
- A requirements-to-graph-to-owner matrix: objective 7.2.
- A gate and valid/fault replay results: objective 7.3.
- Monitoring, change triggers and fallback: objective 7.4.
- A decision to release, restrict or continue testing: objective 7.5.

Why this matters: An operational plan is inspectable and testable.

Reading map: governance and enforcement

- Cornell CS513: policies, mechanisms and abstraction.
- Cornell CS5430: complete mediation and trusted components.
- Cornell CS513: runtime security automata.
- NIST AI RMF: lifecycle, scope and accountability.

Why this matters: Established systems concepts supply the foundations for agent governance.

Reading map: decisions, data and monitoring

- Berkeley CS188: states, actions, transitions and value.
- Datasheets for Datasets: collection, composition and uses.
- Google ML Crash Course: monitoring production pipelines.

Why this matters: Use the references to deepen a specific deployment decision.